Penetration Test Report

Assessment: e2e-final · **Category:** Web · **Scope:** 127.0.0.1:8899 (lab WP site)
Generated: 2026-10-29 11:24 UTC · **Methodology:** NIST SP 800-115 / OWASP WSTG

Executive Summary

This report documents a web application penetration test performed against 127.0.0.1:8899 (lab WP site). A total of **18** finding(s) were recorded: 3 CRITICAL · 4 HIGH · 11 MEDIUM. Findings are prioritized by CVSS v3.1 base score. The test covered reconnaissance, vulnerability scanning, and analysis phases; exploitation and post-exploitation are documented where performed.

Rules of Engagement

Objectives: Full pipeline: ssl/ffuf/sqlmap/nmap_vuln + WP CVE enrichment

Scope: 127.0.0.1:8899 (lab WP site)

Constraints: Lab/offline assessment; allowlisted scanners only; evidence captured verbatim from scanner output.

Introduction

The engagement assessed the web target for common vulnerabilities across reconnaissance, scanning, and analysis. Tooling: nmap, nikto, dirb/gobuster, ffuf, whatweb, openssl (TLS), dig — all executed through the GreyTeam fail-closed execution gate with CVSS v3.1 scoring.

Penetration Testing

Active scanning was performed against the in-scope target. Results below are prioritized by severity.

Vulnerability Testing — Findings

#	Severity	CVSS	Finding	Phase
1	**CRITICAL**	10.0	contact-form-7 5.3.1: CVE-2020-35489 (10.0) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H	2
2	**CRITICAL**	9.9	elementor 2.8.3: CVE-2020-13126 (9.9) CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H	2
3	**CRITICAL**	9.8	elementor 2.8.3: CVE-2020-7109 (9.8) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	2
4	**HIGH**	7.3	Outdated component reported by Nikto CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L	2
5	**HIGH**	7.3	Outdated component reported by Nikto CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L	2
6	**HIGH**	7.3	WordPress xmlrpc.php enabled CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L	2
7	**HIGH**	7.3	WordPress wp-cron.php publicly callable CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L	2
8	**MEDIUM**	5.3	Directory/file discovered (gobuster/dirb) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2
9	**MEDIUM**	5.3	WordPress user enumeration via author feed CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2
10	**MEDIUM**	5.3	Default/test file present (Nikto) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2
11	**MEDIUM**	5.3	Informational header exposure (Nikto) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2
12	**MEDIUM**	5.3	Directory/file discovered (gobuster/dirb) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2
13	**MEDIUM**	5.3	Informational header exposure (Nikto) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2
14	**MEDIUM**	5.3	WordPress version disclosed (readme.html) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2
15	**MEDIUM**	5.3	WordPress plugins directory listable CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2
16	**MEDIUM**	5.3	WordPress plugin version disclosed (no known CVE in local DB) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2
17	**MEDIUM**	5.3	WordPress login page reachable CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2

18	**MEDIUM**	5.3	WordPress /wp-admin/ reachable CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	2

Detailed Findings

1. [CRITICAL] contact-form-7 5.3.1: CVE-2020-35489 (10.0) 10.0

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H` (score 10.0, CRITICAL) · **Phase:** 2 · **Source:** wordpress

Recommendation: The contact-form-7 (aka Contact Form 7) plugin before 5.3.2 for WordPress allows Unrestricted File Upload and remote code execution because a filename may contain special characters. -> Upgrade contact-form-7 past the affected range and re-run; verify the fix against the vendor advisory for CVE-2020-35489.

```
contact-form-7 5.3.1 (detected) vs CVE-2020-35489 affected <5.3.2
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

2. [CRITICAL] elementor 2.8.3: CVE-2020-13126 (9.9) 9.9

CVSS: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H` (score 9.9, CRITICAL) · **Phase:** 2 · **Source:** wordpress

Recommendation: An issue was discovered in the Elementor Pro plugin before 2.9.4 for WordPress, as exploited in the wild in May 2020 in conjunction with CVE-2020-13125. An attacker with the Subscriber role can upload arbitrary executabl -> Upgrade elementor past the affected range and re-run; verify the fix against the vendor advisory for CVE-2020-13126.

```
elementor 2.8.3 (detected) vs CVE-2020-13126 affected <2.9.4
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

3. [CRITICAL] elementor 2.8.3: CVE-2020-7109 (9.8) 9.8

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H` (score 9.8, CRITICAL) · **Phase:** 2 · **Source:** wordpress

Recommendation: The Elementor Page Builder plugin before 2.8.4 for WordPress does not sanitize data during creation of a new template. -> Upgrade elementor past the affected range and re-run; verify the fix against the vendor advisory for CVE-2020-7109.

```
elementor 2.8.3 (detected) vs CVE-2020-7109 affected <2.8.4
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

4. [HIGH] Outdated component reported by Nikto 7.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L` (score 7.3, HIGH) · **Phase:** 2 · **Source:** nikto

Recommendation: Upgrade the named component; verify the vendor CVE applies before remediating.

```
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    127.0.0.1
+ Target Port:        8899
+ Platform:           Unknown
+ Start Time:         2026-10-29 04:23:13 (GMT-7)
---------------------------------------------------------------------------
+ Server: SimpleHTTP/0.6 Python/3.13.5
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests
skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See:
```

```
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [600720] SimpleHTTP/0.6 appears to be outdated (current is at least 1.2).
+ [001578] /backup/: This might be interesting.
+ [003575] /xmlrpc.php: xmlrpc.php was found.
+ [006230] /admin/index.html: Admin login page/section found.
+ [006414] /wp-admin/: Admin login page/section found.
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-
Security-Policy HTTP header with the frame-ancestors directive. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user
agent to render the content of the site in a different fashion to the MIME type. See:
https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-
type-header/
+ 8195 requests: 4 errors and 12 items reported on the remote host
+ End Time:           2026-10-29 04:23:36 (GMT-7) (23 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested


      **************************************************************************
      Portions of the server's headers (Python/3.13.5) are not in
      the Nikto 2.6.0 database or are newer than the known string. Would you like
      to submit this information (*no server specific data*) to CIRT.net
      for a Nikto update (or you may email to sullo@cirt.net) (y/n)?

+ ERROR: Failed to check for updates: 403
```

5. [HIGH] Outdated component reported by Nikto 7.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L` (score 7.3, HIGH) · **Phase:** 2 · **Source:** sqlmap

Recommendation: Upgrade the named component; verify the vendor CVE applies before remediating.

```
___
       __H__
 ___ ___["]_____ ___ ___  {1.10.4#stable}
|_ -| . ['']     | .'| . |
|___|_  ["]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org
```

```
[04:23:50] [WARNING] your sqlmap version is outdated

Usage: python3 sqlmap [options]

sqlmap: error: no such option: -q
```

6. [HIGH] WordPress xmlrpc.php enabled 7.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L` (score 7.3, HIGH) · **Phase:** 2 · **Source:** wordpress

Recommendation: Disable xmlrpc.php (plugin/WP block) unless the mobile app or Jetpack needs it; it is a brute-force + SSRF pivot surface.

```
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

7. [HIGH] WordPress wp-cron.php publicly callable 7.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L` (score 7.3, HIGH) · **Phase:** 2 · **Source:** wordpress

Recommendation: Restrict /wp-cron.php (auth token or IP allowlist); a public wp-cron is a DoS and scheduled-job trigger surface.

```
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

8. [MEDIUM] Directory/file discovered (gobuster/dirb) 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** nikto

Recommendation: Confirm each discovered path; remove or protect non-public directories (backups, .git, admin panels).

```
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    127.0.0.1
+ Target Port:        8899
+ Platform:           Unknown
+ Start Time:         2026-10-29 04:23:13 (GMT-7)
---------------------------------------------------------------------------
+ Server: SimpleHTTP/0.6 Python/3.13.5
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests
```

```
skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [600720] SimpleHTTP/0.6 appears to be outdated (current is at least 1.2).
+ [001578] /backup/: This might be interesting.
+ [003575] /xmlrpc.php: xmlrpc.php was found.
+ [006230] /admin/index.html: Admin login page/section found.
+ [006414] /wp-admin/: Admin login page/section found.
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-
Security-Policy HTTP header with the frame-ancestors directive. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user
agent to render the content of the site in a different fashion to the MIME type. See:
https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-
type-header/
+ 8195 requests: 4 errors and 12 items reported on the remote host
+ End Time:           2026-10-29 04:23:36 (GMT-7) (23 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested


      ************************************************************************
      Portions of the server's headers (Python/3.13.5) are not in
      the Nikto 2.6.0 database or are newer than the known string. Would you like
      to submit this information (*no server specific data*) to CIRT.net
      for a Nikto update (or you may email to sullo@cirt.net) (y/n)?

+ ERROR: Failed to check for updates: 403
```

9. [MEDIUM] WordPress user enumeration via author feed 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** dirb

Recommendation: Disable author archives (?author=1) or restrict /wp-json and /?author= behind auth; hide user IDs in the front end.

```
-----------------
DIRB v2.22
By The Dark Raver
-----------------
```

```
START_TIME: Thu Oct 29 04:23:36 2026
URL_BASE: http://127.0.0.1:8899/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

-----------------

*** Generating Wordlist...

GENERATED WORDS: 4612

---- Scanning URL: http://127.0.0.1:8899/ ----
*** Calculating NOT_FOUND code...


--> Testing: http://127.0.0.1:8899/.bash_history

--> Testing: http://127.0.0.1:8899/.bashrc

--> Testing: http://127.0.0.1:8899/.cache

--> Testing: http://127.0.0.1:8899/.config

--> Testing: http://127.0.0.1:8899/.cvs

--> Testing: http://127.0.0.1:8899/.cvsignore

--> Testing: http://127.0.0.1:8899/.forward

--> Testing: http://127.0.0.1:8899/.git/HEAD

--> Testing: http://127.0.0.1:8899/.history

--> Testing: http://127.0.0.1:8899/.hta

--> Testing: http://127.0.0.1:8899/.htaccess

--> Testing: http://127.0.0.1:8899/.htpasswd

--> Testing: http://127.0.0.1:8899/.listing

--> Testing: http://127.0.0.1:8899/.listings

--> Testing: http://127.0.0.1:8899/.mysql_history

--> Testing: http://127.0.0.1:8899/.passwd

--> Testing: http://127.0.0.1:8899/.perf

--> Testing: http://127.0.0.1:8899/.profile

--> Testing: http://127.0.0.1:8899/.rhosts

--> Testing: http://127.0.0.1:8899/.sh_history
```

```
--> Testing: http://127.0.0.1:8899/.ssh

--> Testing: http://127.0.0.1:8899/.subversion

--> Testing: http://127.0.0.1:8899/.svn

--> Testing: http://127.0.0.1:8899/.svn/entries

--> Testing: http://127.0.0.1:8899/.swf

--> Testing: http://127.0.0.1:8899/.web

--> Testing: http://127.0.0.1:8899/@

--> Testing: http://127.0.0.1:8899/_
```

10. [MEDIUM] Default/test file present (Nikto) 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** dirb

Recommendation: Remove default/test files (e.g. /default.php, /test, index files) before production.

```
-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Thu Oct 29 04:23:36 2026
URL_BASE: http://127.0.0.1:8899/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

-----------------

*** Generating Wordlist...

GENERATED WORDS: 4612

---- Scanning URL: http://127.0.0.1:8899/ ----
*** Calculating NOT_FOUND code...


--> Testing: http://127.0.0.1:8899/.bash_history

--> Testing: http://127.0.0.1:8899/.bashrc

--> Testing: http://127.0.0.1:8899/.cache
```

```
--> Testing: http://127.0.0.1:8899/.config

--> Testing: http://127.0.0.1:8899/.cvs

--> Testing: http://127.0.0.1:8899/.cvsignore

--> Testing: http://127.0.0.1:8899/.forward

--> Testing: http://127.0.0.1:8899/.git/HEAD

--> Testing: http://127.0.0.1:8899/.history

--> Testing: http://127.0.0.1:8899/.hta

--> Testing: http://127.0.0.1:8899/.htaccess

--> Testing: http://127.0.0.1:8899/.htpasswd

--> Testing: http://127.0.0.1:8899/.listing

--> Testing: http://127.0.0.1:8899/.listings

--> Testing: http://127.0.0.1:8899/.mysql_history

--> Testing: http://127.0.0.1:8899/.passwd

--> Testing: http://127.0.0.1:8899/.perf

--> Testing: http://127.0.0.1:8899/.profile

--> Testing: http://127.0.0.1:8899/.rhosts

--> Testing: http://127.0.0.1:8899/.sh_history

--> Testing: http://127.0.0.1:8899/.ssh

--> Testing: http://127.0.0.1:8899/.subversion

--> Testing: http://127.0.0.1:8899/.svn

--> Testing: http://127.0.0.1:8899/.svn/entries

--> Testing: http://127.0.0.1:8899/.swf

--> Testing: http://127.0.0.1:8899/.web

--> Testing: http://127.0.0.1:8899/@

--> Testing: http://127.0.0.1:8899/_
```

11. [MEDIUM] Informational header exposure (Nikto) 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** dirb

Recommendation: Strip or reduce Server / X-Powered-By / version headers.

```
-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Thu Oct 29 04:23:36 2026
URL_BASE: http://127.0.0.1:8899/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

-----------------

*** Generating Wordlist...

GENERATED WORDS: 4612

---- Scanning URL: http://127.0.0.1:8899/ ----
*** Calculating NOT_FOUND code...


--> Testing: http://127.0.0.1:8899/.bash_history

--> Testing: http://127.0.0.1:8899/.bashrc

--> Testing: http://127.0.0.1:8899/.cache

--> Testing: http://127.0.0.1:8899/.config

--> Testing: http://127.0.0.1:8899/.cvs

--> Testing: http://127.0.0.1:8899/.cvsignore

--> Testing: http://127.0.0.1:8899/.forward

--> Testing: http://127.0.0.1:8899/.git/HEAD

--> Testing: http://127.0.0.1:8899/.history

--> Testing: http://127.0.0.1:8899/.hta

--> Testing: http://127.0.0.1:8899/.htaccess

--> Testing: http://127.0.0.1:8899/.htpasswd

--> Testing: http://127.0.0.1:8899/.listing
```

```
--> Testing: http://127.0.0.1:8899/.listings

--> Testing: http://127.0.0.1:8899/.mysql_history

--> Testing: http://127.0.0.1:8899/.passwd

--> Testing: http://127.0.0.1:8899/.perf

--> Testing: http://127.0.0.1:8899/.profile

--> Testing: http://127.0.0.1:8899/.rhosts

--> Testing: http://127.0.0.1:8899/.sh_history

--> Testing: http://127.0.0.1:8899/.ssh

--> Testing: http://127.0.0.1:8899/.subversion

--> Testing: http://127.0.0.1:8899/.svn

--> Testing: http://127.0.0.1:8899/.svn/entries

--> Testing: http://127.0.0.1:8899/.swf

--> Testing: http://127.0.0.1:8899/.web

--> Testing: http://127.0.0.1:8899/@

--> Testing: http://127.0.0.1:8899/_
```

12. [MEDIUM] Directory/file discovered (gobuster/dirb) 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** dirb

Recommendation: Confirm each discovered path; remove or protect non-public directories (backups, .git, admin panels).

```
-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Thu Oct 29 04:23:36 2026
URL_BASE: http://127.0.0.1:8899/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

-----------------
```

```
*** Generating Wordlist...

GENERATED WORDS: 4612

---- Scanning URL: http://127.0.0.1:8899/ ----
*** Calculating NOT_FOUND code...


--> Testing: http://127.0.0.1:8899/.bash_history

--> Testing: http://127.0.0.1:8899/.bashrc

--> Testing: http://127.0.0.1:8899/.cache

--> Testing: http://127.0.0.1:8899/.config

--> Testing: http://127.0.0.1:8899/.cvs

--> Testing: http://127.0.0.1:8899/.cvsignore

--> Testing: http://127.0.0.1:8899/.forward

--> Testing: http://127.0.0.1:8899/.git/HEAD

--> Testing: http://127.0.0.1:8899/.history

--> Testing: http://127.0.0.1:8899/.hta

--> Testing: http://127.0.0.1:8899/.htaccess

--> Testing: http://127.0.0.1:8899/.htpasswd

--> Testing: http://127.0.0.1:8899/.listing

--> Testing: http://127.0.0.1:8899/.listings

--> Testing: http://127.0.0.1:8899/.mysql_history

--> Testing: http://127.0.0.1:8899/.passwd

--> Testing: http://127.0.0.1:8899/.perf

--> Testing: http://127.0.0.1:8899/.profile

--> Testing: http://127.0.0.1:8899/.rhosts

--> Testing: http://127.0.0.1:8899/.sh_history

--> Testing: http://127.0.0.1:8899/.ssh

--> Testing: http://127.0.0.1:8899/.subversion

--> Testing: http://127.0.0.1:8899/.svn
```

```
--> Testing: http://127.0.0.1:8899/.svn/entries

--> Testing: http://127.0.0.1:8899/.swf

--> Testing: http://127.0.0.1:8899/.web

--> Testing: http://127.0.0.1:8899/@

--> Testing: http://127.0.0.1:8899/_
```

13. [MEDIUM] Informational header exposure (Nikto) 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** sqlmap

Recommendation: Strip or reduce Server / X-Powered-By / version headers.

```
___
       __H__
 ___ ___["]_____ ___ ___  {1.10.4#stable}
|_ -| . ['] |  | .'| . |
|___|_  ["]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[04:23:50] [WARNING] your sqlmap version is outdated

Usage: python3 sqlmap [options]

sqlmap: error: no such option: -q
```

14. [MEDIUM] WordPress version disclosed (readme.html) 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** wordpress

Recommendation: Remove /readme.html (or block it) so the exact WP core version is not fingerprintable; keep core patched regardless.

```
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
```

```
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

15. [MEDIUM] WordPress plugins directory listable 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** wordpress

Recommendation: Deny directory listing on /wp-content/plugins/; audit the named plugins for known CVEs and remove unused ones.

```
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
```

```
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

16. [MEDIUM] WordPress plugin version disclosed (no known CVE in local DB) 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** wordpress

Recommendation: Upgrade the named plugin to the latest release and re-run; the local CVE DB (data/wp-cve-db.json) will then cite the specific CVE if one applies. Plugins are the most common WP RCE vector.

```
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

17. [MEDIUM] WordPress login page reachable 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** wordpress

Recommendation: Move/rename the login URL or gate it (WAF, rate-limit, 2FA). A reachable wp-login.php invites credential brute-forcing.

```
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

18. [MEDIUM] WordPress /wp-admin/ reachable 5.3

CVSS: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N` (score 5.3, MEDIUM) · **Phase:** 2 · **Source:** wordpress

Recommendation: Confirm /wp-admin/ behavior; restrict or redirect if the dashboard should not be publicly discoverable.

```
[wordpress probes] base=http://127.0.0.1:8899
http://127.0.0.1:8899/readme.html -> 200
```

```
wp-version-disclose: 6.4.3
http://127.0.0.1:8899/wp-json/ -> 0
http://127.0.0.1:8899/wp-json/wp/v2/users -> 0
http://127.0.0.1:8899/wp-content/plugins/ -> 200
wp-plugin-enum: <html><title>Index of /wp-content/plugins/</title><body>
<ul>
<li><a href="contact-form-7/">contact-form-7/</a></li>
<li><a href="elementor/">elementor/</a></li>
<li><a href="wordfence/">wordfence/</a></li>
<li><a href="hello/">hello/</a></li>
</ul>
</body></html>

wp-plugin-outdated: contact-form-7 5.3.1
wp-plugin-outdated: elementor 2.8.3
wp-plugin-outdated: wordfence 7.8.0
wp-plugin-outdated: hello 1.2.3
http://127.0.0.1:8899/xmlrpc.php -> 200
wp-xmlrpc-enabled: status 200
http://127.0.0.1:8899/wp-cron.php -> 200
wp-cron-exposed: status 200
http://127.0.0.1:8899/wp-login.php -> 200
wp-login-exposed: status 200
http://127.0.0.1:8899/wp-admin/ -> 200
wp-admin-exposed: status 200
```

Post-Testing Actions

Recommendations are listed per finding above. Re-test after remediation to confirm closure. No persistent backdoors or test artifacts were left on the target beyond recorded evidence.

Methodology

Phases followed NIST SP 800-115: (1) Reconnaissance & Enumeration — DNS, technology fingerprinting, TLS analysis; (2) Scanning & Analysis — port scan, web vulnerability scan (nikto), directory brute-force (dirb/ffuf), vuln NSE; (3) Exploitation — manual, documented; (4) Post-Exploitation — documented. CVSS v3.1 base scores computed locally; severity bands: CRITICAL ≥9.0, HIGH ≥7.0, MEDIUM ≥4.0, LOW >0, INFO =0.

Phase 1 — Reconnaissance & Enumeration

▶ **wp_probe · wordpress:**

▶ **scan_output · sqlmap**

- ▶ **scan_output · nmap_vuln**
- ▶ **scan_output · ffuf**
- ▶ **scan_output · dirb**
- ▶ **scan_output · nikto**
- ▶ **scan_output · nmap_quick**
- ▶ **ssl · ssl:http://127.0.0.1:8899:443**
- ▶ **tech · whatweb:http://127.0.0.1:8899**

Appendix — Evidence

Full scanner output is retained in the assessment store. Key evidence is shown inline with each finding above.